

NIST CSF 2.0

Step 6 — Prioritize and Build a Remediation Roadmap

Industry-Style GRC Deliverable | From Gap Assessment to Executable Remediation Plan

Organization	LearnSphere EdTech
Framework	NIST Cybersecurity Framework (CSF) 2.0
Source	Step 5 — Gap Calculation & Prioritization
Assessment / Roadmap Date	07-Sep-2026
Roadmap Horizon	0–3 months 3–6 months 6–12 months
Focus	Children's-data governance, parental consent, data minimization and student-record access controls.
Baseline	Current 1.79/4 Target 3.04/4 Overall Gap 1.25

Purpose: not every NIST CSF gap should be remediated at the same time. This document converts the Step 5 findings into a risk-based sequence, identifies the top six priorities, assigns implementation horizons, and defines ownership and measurable acceptance criteria.

1. Step 6 Objective and Prioritization Method

LearnSphere is assumed to have an existing but partly ad hoc security posture. Step 6 therefore focuses on practical risk reduction rather than creating controls from a blank slate. The first wave concentrates on gaps where remediation materially reduces exposure to unauthorized access, children's-data misuse, privacy impact and loss of governance visibility.

Prioritization factors

Factor	Weight	How it is assessed
Regulatory / contractual exposure	30%	Potential privacy, contractual, customer or regulatory consequence if the gap remains unresolved.
Risk-reduction impact	35%	Expected reduction in likelihood or impact of unauthorized access, disclosure, misuse, disruption or loss.
Cost / effort to fix	15%	Relative people, technology, process and budget effort. Lower effort receives a higher score.
Dependency / enablement	20%	Extent to which remediation enables other outcomes or removes a foundational blocker.

Scoring formula: Weighted Priority Score = (Regulatory × 0.30) + (Risk Reduction × 0.35) + (Effort × 0.15) + (Dependency × 0.20). Each factor is rated from 1 to 5. The maximum score is 5.00.

This weighted score is an internal GRC prioritization method. It is not an official NIST maturity or scoring mechanism. The NIST CSF 2.0 Current/Target Profile remains the assessment basis; the weighted score is used only to sequence remediation.

2. Step 5 Baseline Driving the Roadmap

Function	Current	Target	Gap	Priority
Govern	1.75	3.00	1.25	High
Identify	1.75	3.00	1.25	High
Protect	1.75	3.25	1.50	Critical
Detect	1.75	3.00	1.25	High
Respond	2.00	3.00	1.00	Medium-High
Recover	1.75	3.00	1.25	Medium
Overall	1.79	3.04	1.25	Critical / High focus

The Protect Function has the largest functional gap at 1.50. Student-record access governance is therefore the leading remediation priority. The six selected gaps below are the highest-value first-wave initiatives based on the Step 5 gap magnitude and the weighted management factors.

3. Top Six Gaps — Management Priority Register

The table is ranked using the Step 5 gap size first, followed by risk sensitivity and weighted prioritization. A two-point gap indicates the largest maturity movement in the current assessment.

Rank	Gap ID	NIST	Function	C→T	Gap	Priority	Score
1	GAP-09	PR.AA-05	Protect	2→4	2	Critical	4.70
2	GAP-01	GV.OC-03	Govern	1→3	2	High	4.70
3	GAP-06	ID.AM-07	Identify	1→3	2	High	4.70
4	GAP-12	PR.DS-10	Protect	1→3	2	High	4.50
5	GAP-16	DE.AE-04	Detect	1→3	2	High	4.05
6	GAP-24	RC.IM-01	Recover	1→3	2	Medium	3.25

1. GAP-09 | PR.AA-05

Current → Target: 2→4 Gap: 2 Priority: Critical Weighted score: 4.70/5.00

Current-state issue: Student-record access permissions and privileged entitlements are not consistently governed through evidence-based least privilege, separation of duties and recurring review.

Remediation: Formal RBAC; least privilege; SoD; quarterly access certification; privileged-account register; JML controls; exception management; access metrics.

2. GAP-01 | GV.OC-03

Current → Target: 1→3 Gap: 2 Priority: High Weighted score: 4.70/5.00

Current-state issue: Legal, privacy, contractual and children's-data requirements are not consistently translated into operational requirements.

Remediation: Create a children's-data requirements register covering privacy, parental consent, purpose limitation, retention and contractual obligations; assign owners and review cadence.

3. GAP-06 | ID.AM-07

Current → Target: 1→3 Gap: 2 Priority: High Weighted score: 4.70/5.00

Current-state issue: The authoritative inventory of designated/sensitive student data and metadata is incomplete.

Remediation: Create an authoritative student-data inventory covering data type, purpose, owner, location, sensitivity, flow and retention.

4. GAP-12 | PR.DS-10

Current → Target: 1→3 Gap: 2 Priority: High Weighted score: 4.50/5.00

Current-state issue: Retention and disposal are not consistently enforced across systems containing student information.

Remediation: Define retention schedules, deletion mechanisms, exceptions and verification for records, exports and other copies.

5. GAP-16 | DE.AE-04

Current → Target: 1→3 Gap: 2 Priority: High Weighted score: 4.05/5.00

Current-state issue: Correlation between IAM events, application activity and student-record access is not consistently defined.

Remediation: Develop SIEM correlation rules and detection use cases for anomalous student-record access, privileged activity and identity/application events.

6. GAP-24 | RC.IM-01

Current → Target: 1→3 Gap: 2 Priority: Medium Weighted score: 3.25/5.00

Current-state issue: Lessons learned are not systematically converted into tracked, owned and verified improvements.

Remediation: Establish a post-incident/post-exercise improvement process with owners, due dates, risk linkage and closure verification.

4. Detailed Three-Phase Remediation Roadmap

Horizon	Workstream	Key activities	NIST linkage
0–3 MONTHS	FOUNDATION & HIGH-RISK CONTAINMENT	- Establish children's-data governance owner/RACI and requirements register. - Complete emergency review of student-record and privileged access. - Implement RBAC, least privilege, SoD and quarterly certification design. - Establish authoritative student-data inventory and metadata baseline. - Define retention/disposal rules and immediate exceptions. - Define priority detection use cases for student-record access. - Establish improvement-action tracker.	GAP-09, GAP-01, GAP-06, GAP-12, plus supporting GV.RR-02, GV.PO-01, ID.RA-05
3–6 MONTHS	FORMALIZE & OPERATIONALIZE	- Integrate requirements into policies, product and change workflows. - Complete application-to-data and third-party mapping. - Operationalize recurring access certification and privileged metrics. - Deploy deletion controls and verification. - Deploy/tune SIEM correlation rules and investigation metrics. - Formalize student-data incident playbooks and communications. - Conduct targeted assurance reviews.	GAP-16, GAP-24, plus ID.AM-02, ID.RA-04, PR.AA-03, PR.DS-01, DE.CM-01, DE.AE-02, RS.MI-01
6–12 MONTHS	TEST, MEASURE & OPTIMIZE	- Run scenario-based recovery exercises for ransomware/database compromise/student-data loss. - Validate RTO/RPO dependencies and recovery communications. - Strengthen third-party monitoring and assurance. - Trend access, retention, detection and remediation KPIs. - Verify corrective actions through internal assessment. - Reassess the NIST CSF 2.0 Current Profile against the Target Profile.	RC.RP-01, RC.RP-03, RC.CO-02, DE.CM-06, and validation of all prior remediation

5. Dependency Logic

The roadmap intentionally starts with governance and visibility. LearnSphere cannot demonstrate reliable minimization, retention or access decisions if it cannot identify what student data exists, why it is processed, where it resides and who owns it. Once that foundation is established, access and lifecycle safeguards can be measured more effectively, while detection and recovery improvements can be validated against a known critical-data population.

6. Ownership, Milestones and Acceptance Criteria

Workstream	Accountable owner	Acceptance criterion
Children's-data governance	GRC / Privacy Lead	Requirements register approved; RACI assigned; review cadence active.
Student-data inventory	Data Governance / IT	100% of identified in-scope repositories have owner, purpose, location, sensitivity and retention metadata.
Student-record access	IAM / Security Engineering	Quarterly certification completed; privileged accounts inventoried; exceptions approved and tracked.
Retention / disposal	Data Governance / Application Owners	Retention schedule approved; deletion evidence available; sample verification completed.
Detection engineering	SOC / Security Operations	Priority correlation rules tested; coverage and investigation metrics reported.
Continual improvement	GRC / Security Management	Applicable incidents/exercises produce owned actions with due dates and closure verification.

7. Recommended Management KPIs

KPI	Initial target	Frequency
Student-record access certification	≥98% on-time; 100% critical exceptions reviewed	Monthly / Quarterly
Privileged accounts	100% inventoried and reviewed; dormant accounts handled within SLA	Monthly
Student-data inventory	≥95% coverage during implementation; target 100% in-scope repositories	Monthly
Retention compliance	≥95% sampled records aligned to approved rule; all exceptions documented	Quarterly
Detection coverage	Defined coverage percentage for critical systems/data paths	Monthly
Remediation closure	≥90% actions closed by due date; overdue high-risk actions escalated	Monthly

8. Implementation Risks and Mitigations

Risk	Potential impact	Mitigation
Incomplete data inventory	Access, retention and monitoring decisions may miss repositories.	Reconcile applications, databases, backups, exports and third parties; require owner attestation.
Access cleanup disruption	Removing excessive access can affect legitimate users.	Use role-based baselines, manager certification, exception workflow and controlled rollback.
Consent requirement ambiguity	Teams may implement inconsistent children's-data requirements.	Maintain one approved requirements register and route interpretation through accountable governance.
Engineering capacity	Security changes compete with product delivery.	Sequence critical risk reduction first and use measurable acceptance criteria for funding/capacity decisions.
Control drift	Controls may weaken after initial implementation.	Use recurring KPIs, certifications, internal reviews and profile reassessment.

9. Step 6 Management Conclusion

The recommended strategy is to reduce the highest-risk exposure first rather than distribute resources evenly across all 24 Step 5 gaps. Student-record access governance is the immediate critical initiative, followed by children's-data governance, authoritative data visibility and lifecycle protection. Detection correlation and continual improvement are then strengthened so that the security program can demonstrate measurable effectiveness.

By the end of the 6–12 month horizon, management should have sufficient evidence to determine whether the target state is operating consistently and to perform a refreshed NIST CSF 2.0 Current Profile assessment. The roadmap should be treated as a living management plan: dates, owners and priorities may be adjusted when risk, business requirements or technology architecture changes.

10. Approval and Governance

Prepared By	Mr. Meejan Shaikh – GRC Analyst	Signature: _____	Date: 07-Sep-2026
Reviewed By	Information Security Manager	Signature: _____	Date: 07-Sep-2026
Approved By	CISO	Signature: _____	Date: 07-Sep-2026

Document control: LS-NIST-002 | Version 1.0 | NIST CSF 2.0 Project 2 — Step 6 | Assessment/Roadmap Date: 07-Sep-2026 | Internal / Confidential